NestSports / NestAcademy: Security Re-Audit (second pass)

Scope: `backend/`, `frontend/` (web), `NestSports/` (mobile). Method: code reading, `npm audit` on all three packages, and the backend test suite (33 tests, all passing, 15 of them added or repaired in this round). No live pen-test and no production configuration were available. Items marked **[device test]** need a check on a real device or deployed build.

This pass followed the first re-audit (`AUDIT_2026-10_SECURITY_AND_GAPS.md`). First every fix on that list was implemented, then every finding was re-checked against the code.

1. Result at a glance

Area	First audit (2026-10-03)	Previous pass	Now
Critical findings open	3	0	**0**
High findings open	5	2 (web token storage, no CSP)	**0** (CSP is partial, see S-1)
Medium findings open	8	9	**2**
Dependencies with known issues	22	backend 5	backend **0**, web 6, mobile 2

Scorecard (my view, 10 = best): Access control 8 · Input validation 7 · Authentication 8 · Secrets and data at rest 8 · Transport and headers 7 · Dependencies 6.

2. Everything from the first audit, re-checked

ID	Finding	Status	How verified
C-1	`/uploads` guard bypass	**Fixed**	`uploadGuard.js` resolves the path before judging the folder.
C-2	Operator injection, device impersonation	**Fixed**	Global `$`-key strip in `sanitizeInput`; device lookups typed.
C-3	Cross-tenant takeover via employee email	**Fixed**	`createEmployee` rejects emails owned by another academy or role; reset is company- and role-scoped.
H-1	Directory exposes salary, bank, ID	**Fixed**	Non-managers get a minimal projection (`DIRECTORY_FIELDS`).
H-2	Parents reach employee data	**Fixed**	Leaves, attendance, corrections, documents are allow-listed (`NON_PARENT`).
H-3	Stored XSS in print windows	**Fixed**	Report templates use `escapeHtml`.
H-4	Staff can approve or cancel payments	**Fixed**	Verify, reject, assign are owner/HR only; every write is audit-logged (new).
H-5	Legacy `/api/company` flow	**Fixed**	Routes removed; only `GET /me` remains.
M-1	No JWT revocation	**Fixed**	`tokenVersion` plus per-device sessions.
M-2	Upload extension from client	**Fixed**	Extension comes from the sniffed MIME type, with an allow-list.

ID	Finding	Status	How verified
M-3	Cross-tenant payment verify	**Fixed**	Lookup scoped by `company`; Razorpay signature compare now constant-time (new).
M-4	Weak admin-set passwords	**Fixed (new)**	Staff, parent and guardian passwords now use the full policy (8+, upper, lower, number, special). Web and mobile hints and password generators updated to match.
M-5	No web security headers	**Partly fixed**	See S-1.
M-6	Unescaped regex, loose query values	**Fixed**	`escapeRegex` in reports and audit search.
M-7	Rate-limit gaps	**Fixed (new)**	`/iclock`, `/internal/stats`, `/api/crm` and the WhatsApp webhook now have their own limits.
M-8	Dependencies	**Improved**	See S-4.
L-1	Query strings in logs	**Fixed**	Access log prints the path only.
L-2	Secret compared with `!==`	**Fixed (new)**	Constant-time compare in the support webhook.
L-4	WhatsApp webhook fails open	**Fixed (new)**	Without a secret it now refuses everywhere except `NODE_ENV=development`.
L-5	Phone not unique	Open (low)	Phone numbers can still be shared; login by phone OTP resolves all matching accounts and asks the user to choose.
L-6	Account enumeration	Open (low)	Password-reset method lookup still reveals which recovery methods an email has.
L-7	Android release can fall back to the debug key	Open (low)	Left as is so local release builds keep working; never upload such a build.
L-8	Payment WebView origin whitelist	Open **[device test]**	`PaymentWebViewScreen` sets no `originWhitelist`; restricting it could break the gateway form post, so it needs a device test first.
L-9	5 MB JSON limit on every route	Open (low)	Unchanged.

3. New fixes made in this round

1. **Web session token moved out of `localStorage`** into an httpOnly, Secure, SameSite cookie, with a CSRF header requirement. Mobile is unchanged.
2. **Sensitive fields encrypted at rest** (AES-256-GCM): staff bank account, IFSC, PAN, Aadhaar number, and student medical notes. A migration script is provided (not yet run on your data).
3. **Biometric templates masked in every JSON response.** Face vectors and device templates no longer leave the server; the apps' "face enrolled" checks keep working.
4. **WhatsApp OTP gate on confidential documents** (vault, Aadhaar, PAN, résumé).
5. **Audit trail now covers writes** to students, parents, student attendance, subscriptions and payments, payroll, loans, expenses, settings, attendance settings, payment methods and documents.
6. **Data rights.** Every signed-in user can download a copy of their data (web: Account Security; mobile: Account Security). Non-owner users can delete their own account (password-confirmed; personal details removed, payroll history kept anonymously). Terms and Privacy acceptance is now stored as a versioned consent record. Academy owners are pointed to support, because deleting an owner would delete the academy.
7. **Login OTP resend guard** (30 s) and the new route limits above.

8. **Web security headers** (nosniff, referrer policy, permissions policy, `frame-ancestors 'none'`, `object-src 'none'`).
9. **Tests:** new suites for the cookie session, field encryption and biometric masking, plus a tenant-isolation scan that fails if a controller looks up a record by a request id without a company scope. The two stale tests (terms gate, unguarded routes) were repaired.

4. What is still open

S-1 · Full Content-Security-Policy is report-only (Low). The safe directives are enforced. A strict script/style/connect policy is now sent as `Content-Security-Policy-Report-Only`, so it blocks nothing; open the browser console on a deployed copy, fix any violations it lists (Razorpay, fonts, camera), then rename the header to `Content-Security-Policy`.

S-2 · Mobile hardening (Medium) [device test]. No certificate pinning, no jailbreak/root detection, no screenshot blocking on sensitive screens, no app lock. These need native changes and I did not make them blind, because screenshot blocking and app lock change how the app behaves.

S-3 · xlsx (Medium, web and mobile), needs your decision. Excel import and export use `xlsx@0.18.5`, which has an open prototype-pollution and ReDoS advisory when it parses untrusted files. The fixed version (0.20.x) is only published on SheetJS's own server, not the npm registry. My attempt to install it from there was blocked by the permission system, so I stopped. Options: (a) you install it yourself with `npm install https://cdn.sheetjs.com/xlsx-0.20.3/xlsx-0.20.3.tgz` in `frontend/` and `NestSports/` (API-compatible), or (b) replace it with `exceljs` across about 30 screens. Exports are not affected, only importing a malicious file.

S-4 · Other dependency findings. Backend: now clean (`file-type` upgraded to v22 and loaded lazily; image/PDF content checks tested). Web: `react-router` and `postcss-selector-parser`, both needing breaking upgrades. Mobile: `shell-quote` (build toolchain). The earlier critical finding on web and the nodemailer findings on the backend are gone.

S-5 · Existing plaintext data (Medium until migrated). New and edited sensitive values are encrypted, but old values stay plaintext until you run `node scripts/encryptSensitiveFields.js --apply`. Set `FIELD_ENCRYPTION_KEY` first and back up the database.

S-6 · PDFs once downloaded (Low). Documents are encrypted on the server and gated by OTP, but a downloaded file is an ordinary file. Password-protecting the downloaded PDF needs a PDF-encryption tool such as qpdf on the server.

S-7 · Users already signed in on web are now migrated automatically: on the next page load their old `localStorage` token is swapped for the httpOnly cookie and removed.

S-8 · Operations (verify). No evidence in the repo of backups and restore drills, secrets rotation, log alerts on failed-login spikes, or PII scrubbing in Sentry.

5. Product gaps (unchanged)

The market-comparison section of `AUDIT_2026-10_SECURITY_AND_GAPS.md` still stands: batch/timetable model, authorised pickup with OTP, incident log, consent records for biometrics and photos, coach-parent messaging, skill progress, credit packs and waitlists, lead funnel, GST credit notes, multi-branch. Data rights (export and deletion) and the consent model are now in place; the rest are new features rather than fixes.

6. Do these before the next release

1. Set `FIELD_ENCRYPTION_KEY`, back up the database, run the field-encryption migration.
2. Deploy and test on a staging copy: web login, logout, file upload, payment screenshot view, document OTP, delete-account.
3. Watch the report-only Content-Security-Policy for violations, then enforce it.
4. Add the screenshot blocking and app lock, and test the Payment WebView whitelist, on a real device.
5. Decide how to fix `xlsx` (see S-3).